

Access Control Management

Dr. Ruba Alomari

**MIT5600G – Security Policies and Risk
Management**

Recall – Last Week – What is Security Operations (SecOps)?

- **SecOps** the continuous monitoring, detection, investigation, response, and recovery from cybersecurity threats and incidents.
- It refers to the practical, operational side of defending digital infrastructure.
- Security Operations is typically performed by a Security Operations Center (SOC).

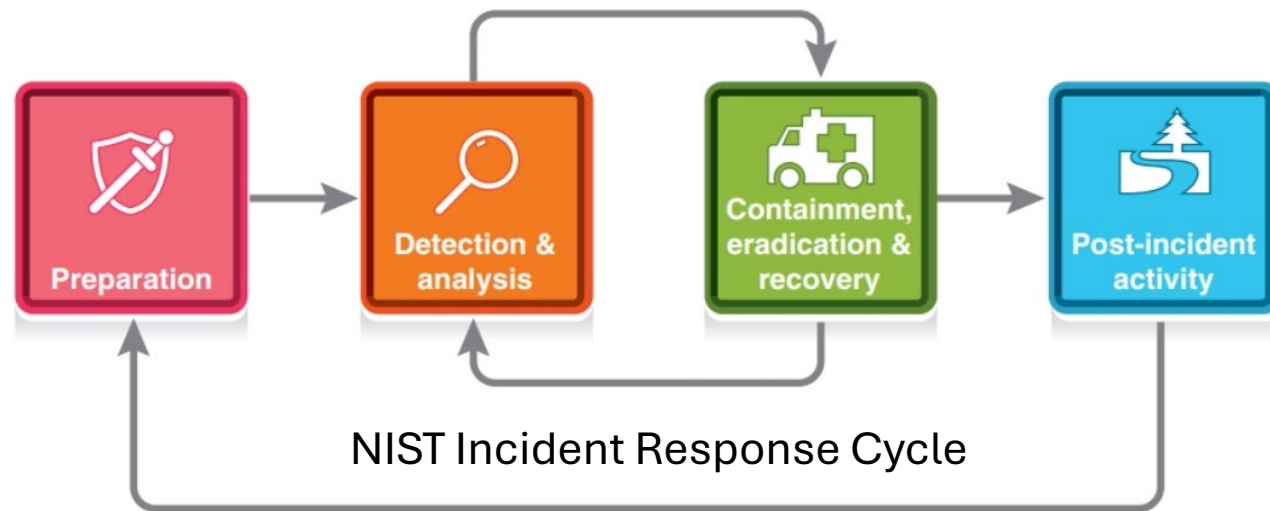


Recall – Last Week – What Does SecOps Cover?

- Core components of SecOps:
 - Security Monitoring
 - Incident Response
 - Threat Intelligence
 - Threat Hunting
 - Digital Forensics
 - Vulnerability Management
 - Threat Detection
 - Log and Event Analysis
 - Reporting and Documentation

Recall – Last Week – What is an IR Plan?

- An incident response plan (IRP) is a roadmap, guidance, and instructions related to preparation, detection and analysis, initial response, containment, eradication and recovery, notification closure and post-incident activity, and documentation and evidence-handling requirements.

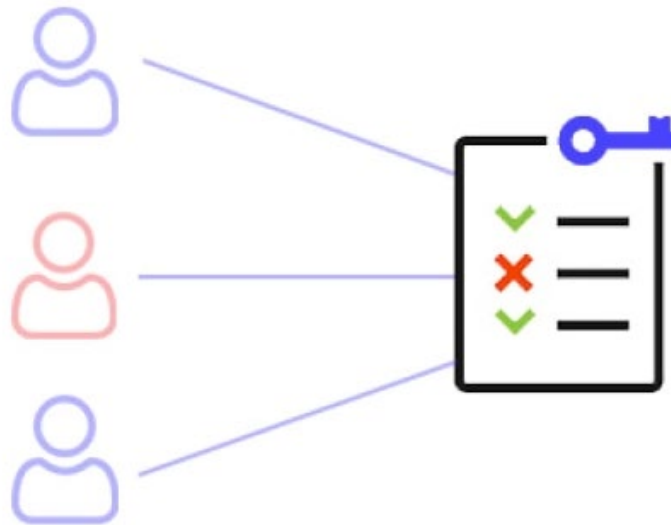


Topics

- Access Control Fundamentals
 - Identify Management
 - Security Posture
 - Principle of Least Privilege and Need-to-Know
 - AAA
 - Access Control Models
- Infrastructure Access Controls
- Managing User Accounts

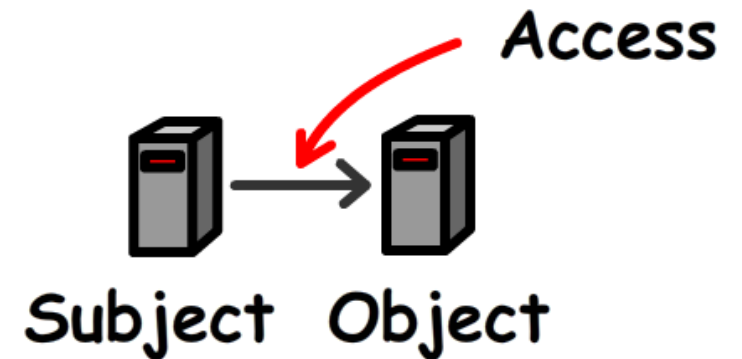
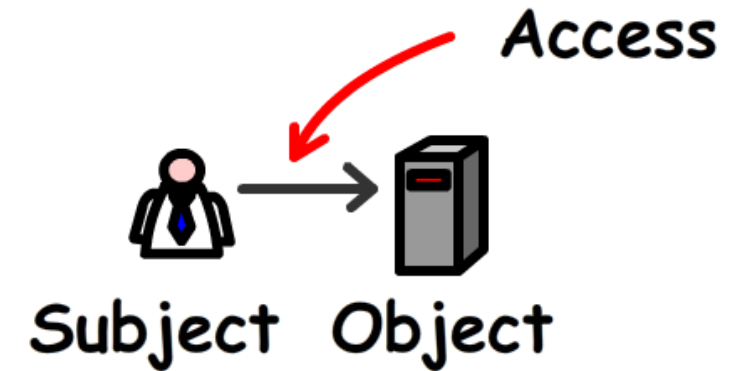
What Are Access Controls?

- Access controls are **security features** that govern how users and processes communicate and interact with systems and resources.
- The primary objective of access controls is to protect the CIA of information and information systems.



Subject vs. Object

- The active entity (i.e., the user or system) that requests access to a resource or data is referred to as the **subject**.
- The passive entity being accessed or being acted upon is referred to as the **object**.

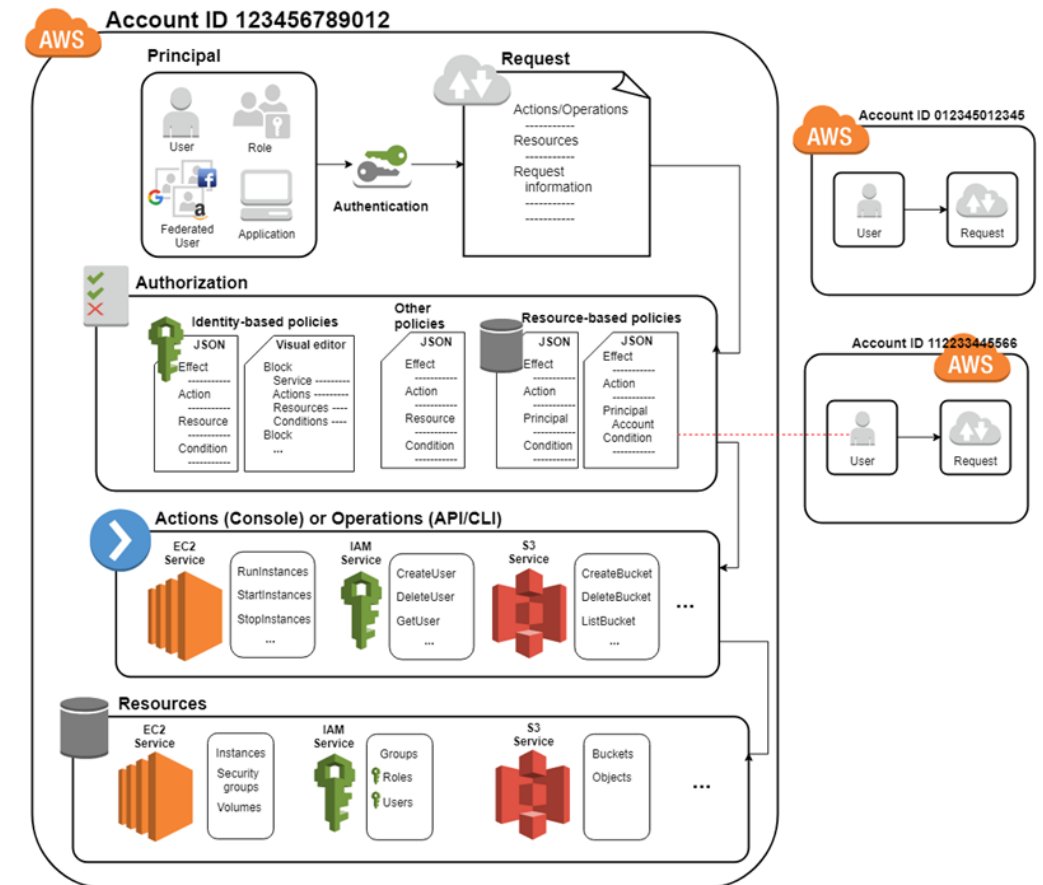


Access Control Attributes

- An identification scheme, an authentication method, and an authorization model are the three common attributes of all access controls.
 - **Identification**: The process by which the subject supplies an identifier to the object.
 - **Authentication**: How identification is proven to be genuine.
 - The subject supplies verifiable credentials to the object.
 - **Authorization**: Assigning authenticated subjects the permission to carry out specific operations.

Identity and Access Management (IAM)

- The process for identifying, authenticating, and authorizing users or groups of users to have access to applications, systems, or networks is referred to as identity management.
- It is done by **associating user permissions with established identities.**
- Identity management is focused on authentication, whereas access management is aimed at authorization.



How IAM works

<https://docs.aws.amazon.com/IAM/latest/UserGuide/intro-structure.html>

Access Controls

- Access controls can be technical (e.g., firewalls or passwords), administrative (e.g., separation of duties or dual controls), or physical (e.g., locks, bollards, or turnstiles).
- The **security posture** of an organization determines the default settings for access controls.



**TECHNICAL
CONTROLS**



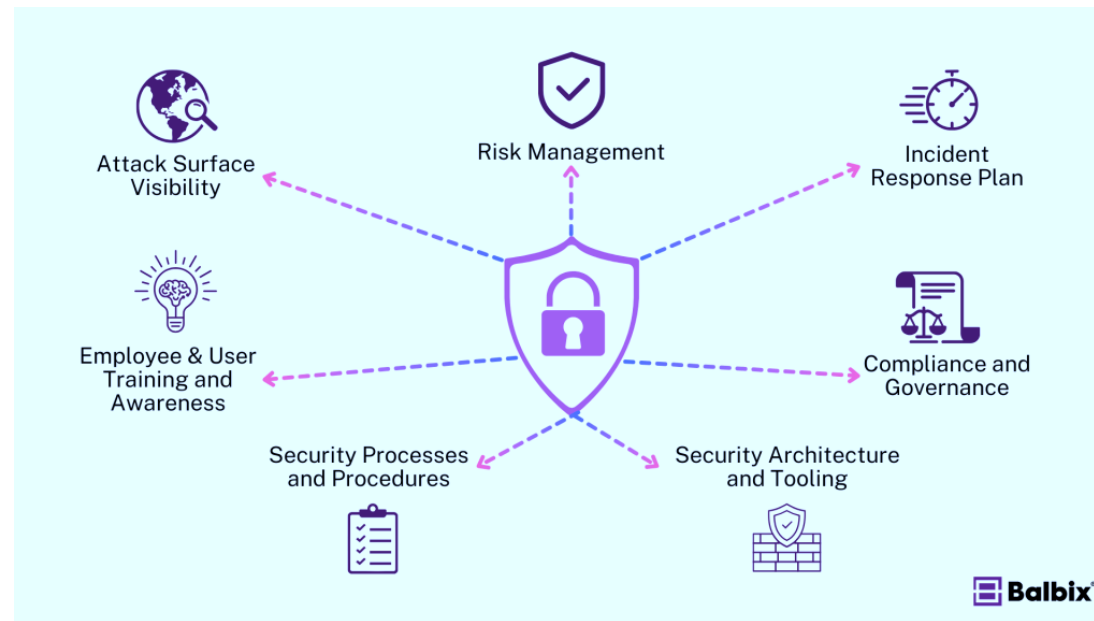
**ADMINISTRATIVE
CONTROLS**



**PHYSICAL
CONTROLS**

What Is a Security Posture?

- A security posture is an organization's **approach to access controls** based on information about an object, such as a host (end system) or network.
- It determines the default settings for access controls.



The Key Components of a Security Posture

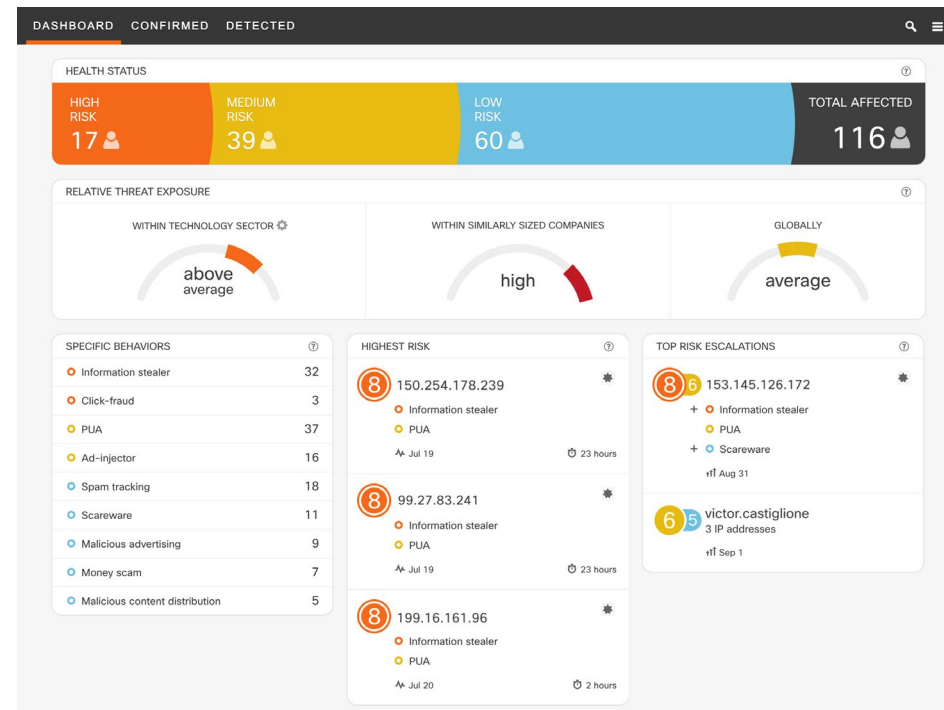
Security Postures

- Two fundamental security postures:
 - **Secure:** “default deny” model.
 - Access that is not explicitly permitted is forbidden.
 - **Open:** “default allow” model.
 - Access that is not explicitly forbidden is permitted.

Source	Destination	Protocol	Port	Action
Any	Any	Any	Any	Allow
Any	Web Server	TCP	443	Allow

End-Point Security Posture Check

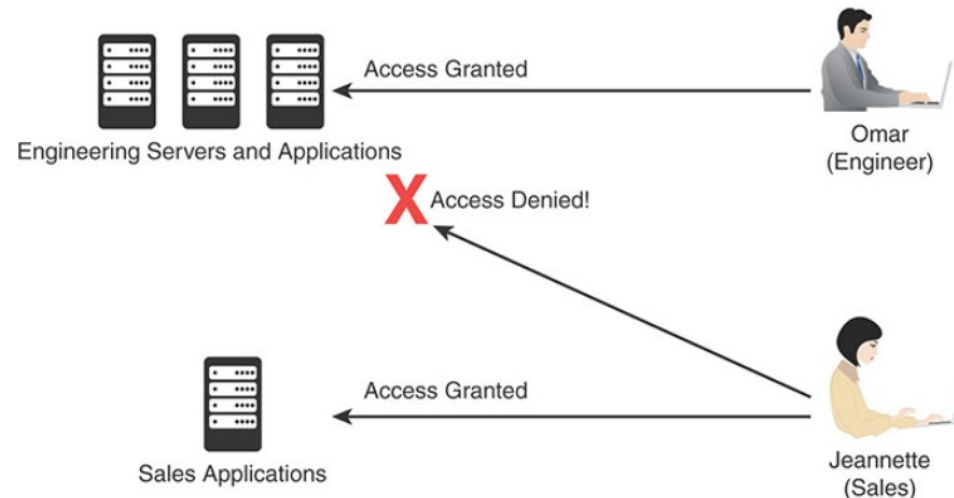
- Network access control (NAC) allows networking devices (e.g., switches, firewalls, wireless access points,...) to **enforce policy** based on **the security posture of a subject** (e.g., a device trying to join the network).
- NAC can provide the following:
 - Identity and trust
 - Visibility
 - Correlation
 - Management
 - Isolation and segmentation
 - Policy Enforcement



Cisco Cognitive Threat Analytics (CTA)

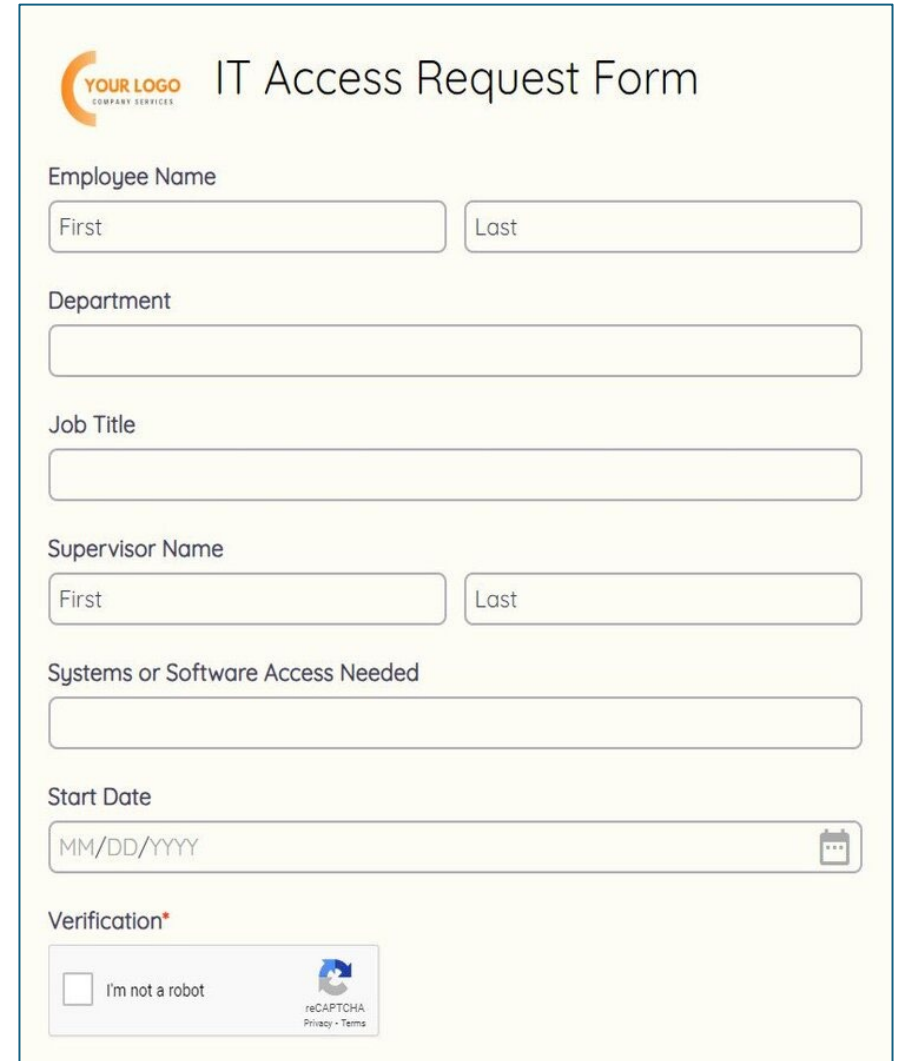
Principle of Least Privilege (PoLP)

- The **principle of least privilege** states that all users should be granted only the level of privilege they need to do their jobs, and no more.
- Examples:
 - A sales account manager has no business having administrator privileges over the network
 - A call center staff member doesn't need access to critical corporate financial data.



Need-to-Know

- Need-to-know means that the subject has a **demonstrated and authorized reason** for being granted access to information.
- Determining who to grant access to should be based on the security principle of need-to-know. The level of access required should be based on the security principle of least privilege.
- Important to explain to employees why they are not “trusted” with all the company’s data.



The image shows a screenshot of an "IT Access Request Form". At the top left is a logo with the text "YOUR LOGO" and "COMPANY SERVICES" below it. The title "IT Access Request Form" is at the top right. The form contains several input fields: "Employee Name" with sub-fields for "First" and "Last"; "Department"; "Job Title"; "Supervisor Name" with sub-fields for "First" and "Last"; "Systems or Software Access Needed"; "Start Date" with a placeholder "MM/DD/YYYY" and a calendar icon; and a "Verification*" section at the bottom with a checkbox for "I'm not a robot" and a reCAPTCHA logo with links for "Privacy" and "Terms".

Separation of Duties

- Separation or Segregation of Duties: An administrative control that dictates that **a single individual should not perform all critical or privileged level duties**.
- **Goal:** safeguard against a single individual performing sufficiently critical or privileged actions that could seriously damage a system or the organization as a whole.
- Example: A network administrator should not have the ability to alter logs on the system.



Rotation of Duties & Mandatory Leave

- To detect and deter fraud and single point of personnel failure (e.g., hit by a bus), an organization should consider:
 - Rotation of duties.
 - Mandatory leave (i.e., forced vacation).



How Is Identity Verified?

- A subject must provide an identity to a system to start the authentication, authorization, and accounting processes.
 - Identities should be unique.
 - Identities should be nondescriptive.
 - It should not be possible to infer the role or function of the user.
 - Identities should be securely issued.



Authentication: Verifying Identity

- Proves the identity of the subject who tries to connect.
 - Subject must supply verifiable credentials, referred to as factors.
 - **Single-factor** authentication: One factor is used.
 - **Multifactor** authentication: Two or more factors are used.
 - **Multilayer** authentication: Two or more of the same type of factors be presented.



I am Alex
Here is my
SOMETHING to
prove it

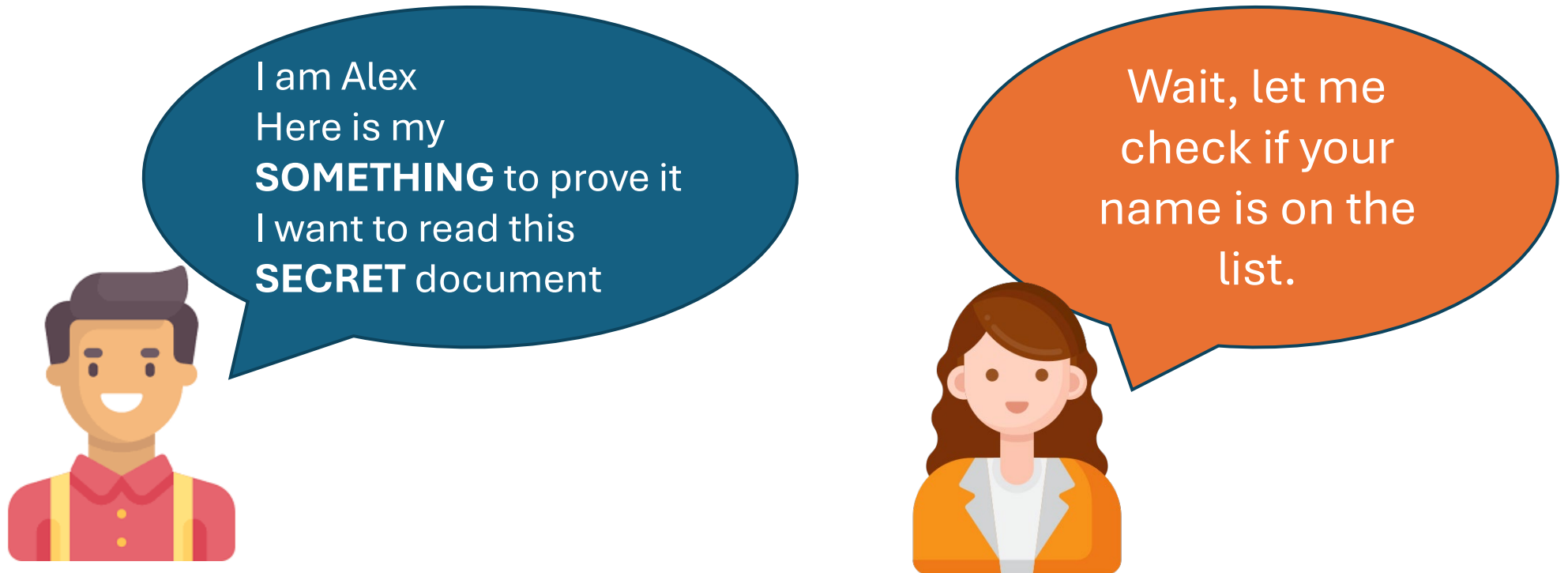
Three Categories of Factors

- Knowledge: Something you know
 - Password
 - PIN
 - Answer to a question
- Possession: Something you have
 - One-time passcode (OTP)
 - Memory cards
 - Smart cards
- Biometrics: Something you are
 - Physiological: Fingerprint, Face, Iris
 - Behavioral: Signature, Keystroke dynamic/pattern



Authorization

- **Authorization** is the process of assigning authenticated subjects permission to carry out a specific operation.
- The authorization model defines how access rights and permissions are granted.



Accounting

- **Accounting** is the process of **auditing** and **monitoring** what a user does once a specific resource is accessed.
- Accounting produces an audit trail log
 - When the user accessed the resource
 - What the user did with that resource
 - When the user stopped using the resource

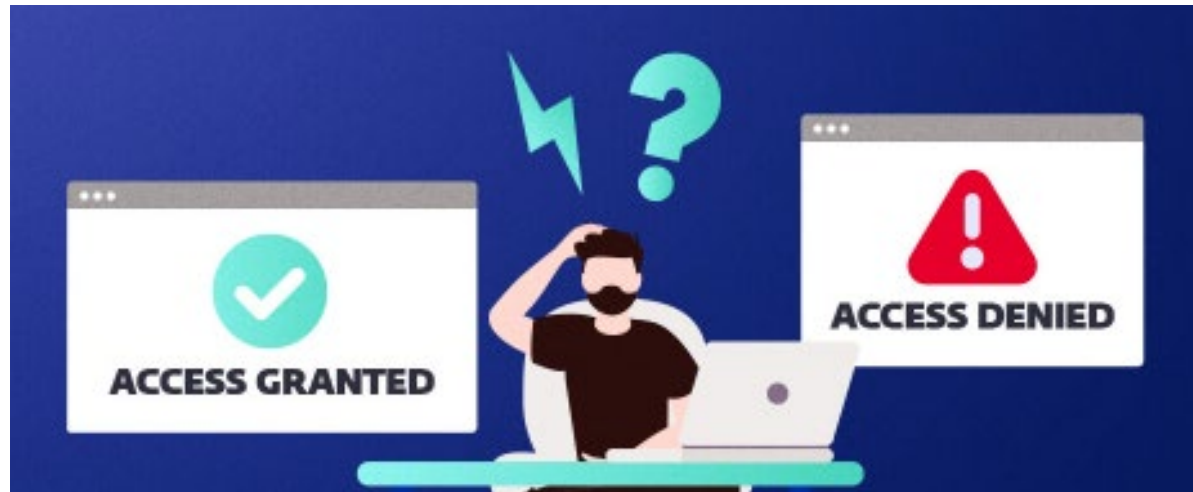


Access Control Lists

- **Access control lists (ACLs)** explicitly define access **permissions** based on multiple **attributes**, usually in the form of rules or lists that associate users/groups with specific permissions (read, write, execute, etc.).
- Criteria often used in ACLs:
 - User ID
 - Group membership
 - Network address (IP)
 - Location
 - Time or date
 - Classification level

Authorization Policy

- An authorization policy should implement two concepts:
 - **Implicit deny:** If no rule is specified for the transaction of the subject/object, the authorization policy should deny the transaction.
 - **Need-to-know:** A subject should be granted access to an object only if the access is needed to carry out the job of the subject.

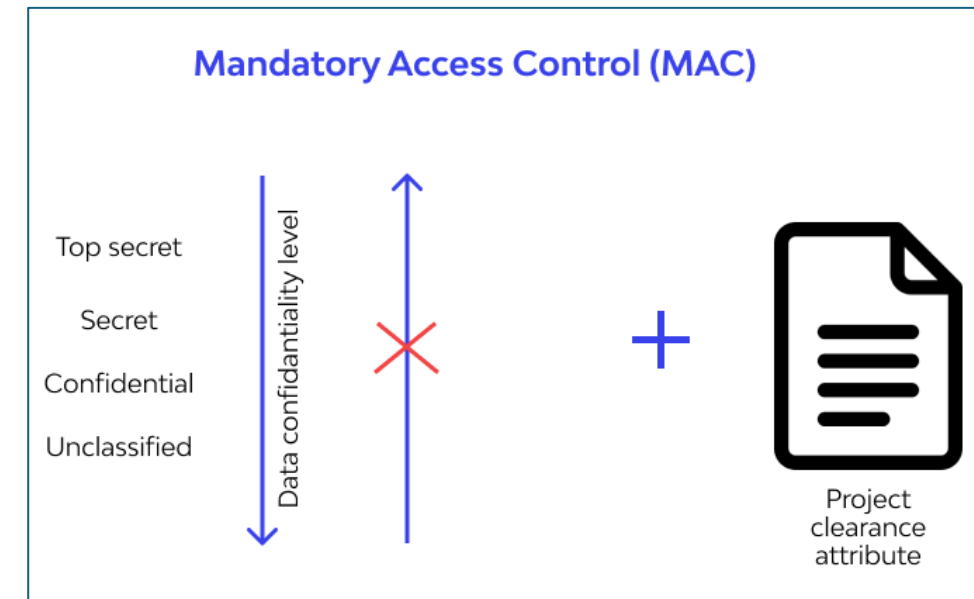


Categories of ACLs

- Main models of access control:
 - Mandatory Access Control (MAC)
 - Discretionary Access Control (DAC)
 - Attribute-based Access Control (ABAC)
 - Rule-Based Access Control
 - Role-Based Access Control (RBAC)

MAC

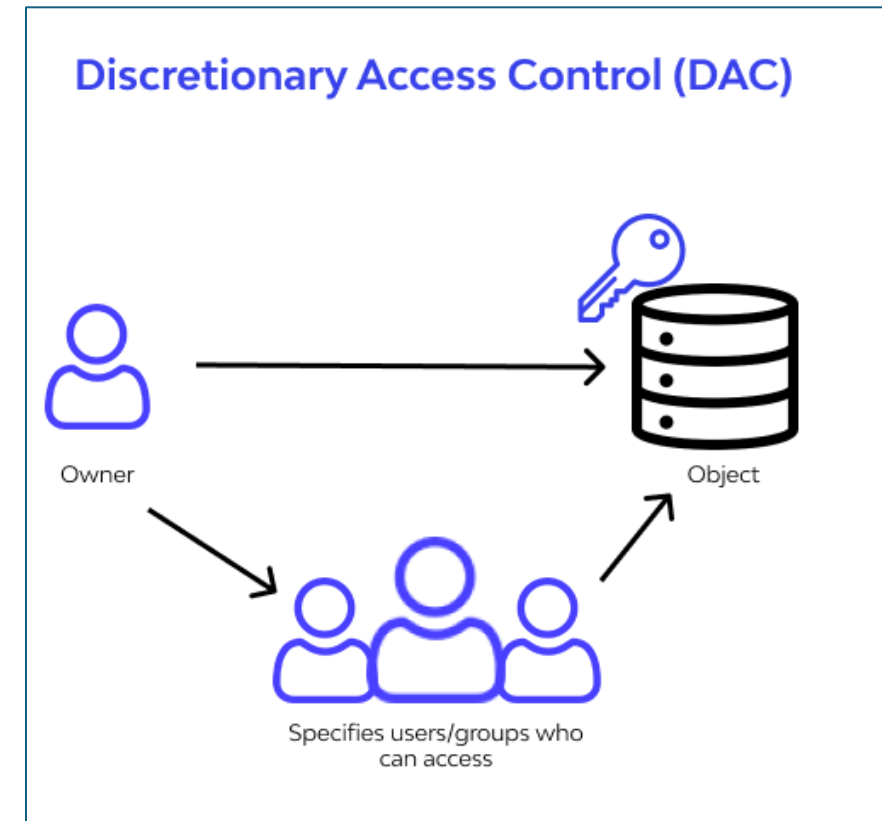
- Mandatory access controls (MACs) are **defined by policy and cannot be modified** by the information owner.
- MACs are primarily used in secure military and government systems that require a high degree of confidentiality.
- An object is assigned a security label that indicates the classification and category of the resource.
- A subject is assigned a security label that indicates a clearance level and assigned categories (based on need-to-know).



<https://www.wallarm.com/>

DAC

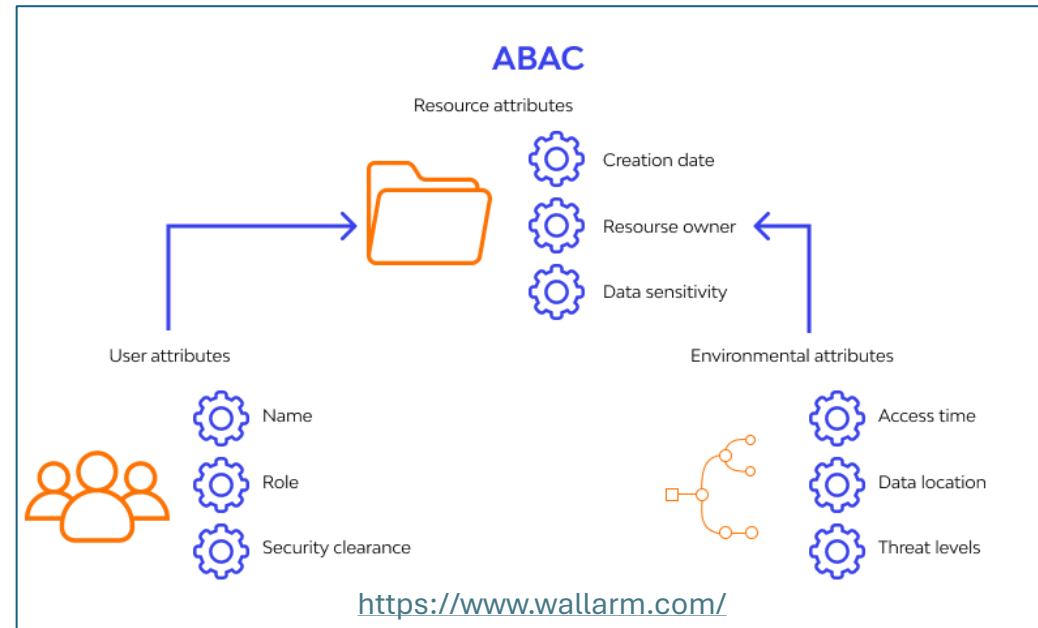
- Discretionary Access Control (DAC): **Data owners decide** who should have access to what information.
- DACs are used in commercial operating systems.
- The object owner builds an ACL that allows or denies access to the object based on the user's unique identity.
- The ACL can reference a user ID or a group (or groups) that the user is a member of.



<https://www.wallarm.com/>

ABAC

- Attribute-based access control (ABAC) is a logical access control model that controls access to objects by evaluating rules against the attributes of entities (both subject and object), operations, and the environment relevant to a request.
- ABAC supports a **complex Boolean rule set** that can evaluate many different attributes.

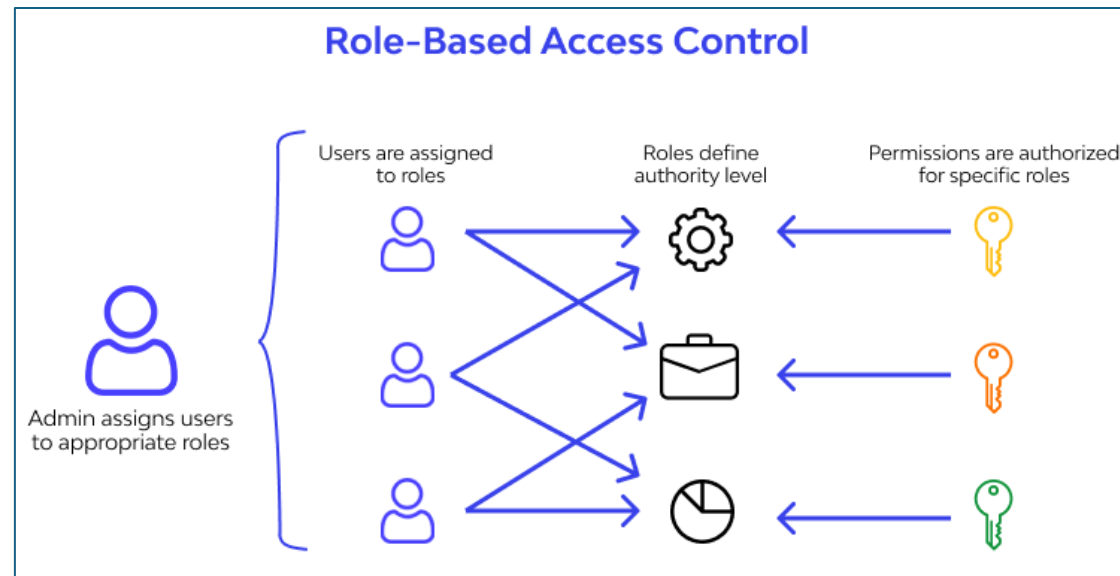


Rule-Based Access Control

- Access is based on criteria that are independent of the user or group account.
- The rules are determined by the resource owner.
- Commonly used criteria include **source or destination address, geographic location, and time of day.**
- Example: The ACL on an application requires that it be accessed from a specific workstation.
- Rule-based access controls can be combined with DACs and RBACs.

Role-Based Access Control (RBAC)

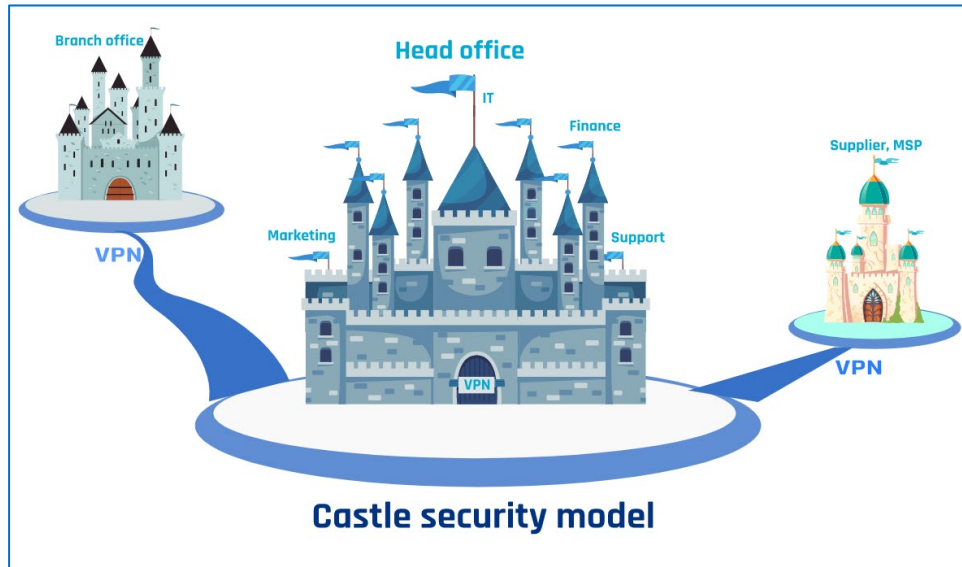
- Role-based Access Control (RBAC): Access permission is based on a specific **role or function**.
- Administrators grant access rights and permissions to roles.
- A user is then associated with a single role.



<https://www.wallarm.com/>

RBAC and Zero Trust /1

- RBAC is an important component in the implementation of a zero-trust security model.
- The zero trust approach to cybersecurity is becoming increasingly important due to the **rise in cyber threats** and the **expanding perimeter** caused by remote work and cloud services.



The Zero Trust Principle – Never Trust, Always Verify

- Zero Trust operates under the assumption that **no entity—internal or external—should be implicitly trusted.**
- It requires continuous verification of identity, context, and device state before granting access.

Your friendly zero trust cheat sheet

☐	A zero trust model should authorize and authenticate user access to all assets and resources, and access should be given based on the company's corresponding policy and on a per-session basis.
☐	Zero trust controls need to be identified and aligned to your systems, users and data. These should be considered from two perspectives:
☐	Security controls for securing internal/cloud infrastructure, networks, systems, applications and data — sometimes classified as the “object.”
☐	Security controls for the protection and authorization of users and endpoints when accessing resources. This should also include administrative access and is classified as the “subject.”
☐	There should be a common set of policies, practices and protocols in place to manage the identity and trust score of users and devices across all systems, including external resources (e.g., software as a service).
☐	The management of zero trust controls need to be unified, and dynamic end-to-end access provisioned based on business-level logic, and not traditional security rules (e.g., IP-based controls).
☐	End-to-end data analytics should be established, providing monitoring and threat detection across the entire architecture, supporting both IT and security operations requirements.
☐	A centralized security posture is adopted, with contextualized risk profiling and advanced policy logic for access authorization.
☐	Existing security controls and processes need to be accounted for, in addition to their suitability and compatibility within the broader zero trust architecture.

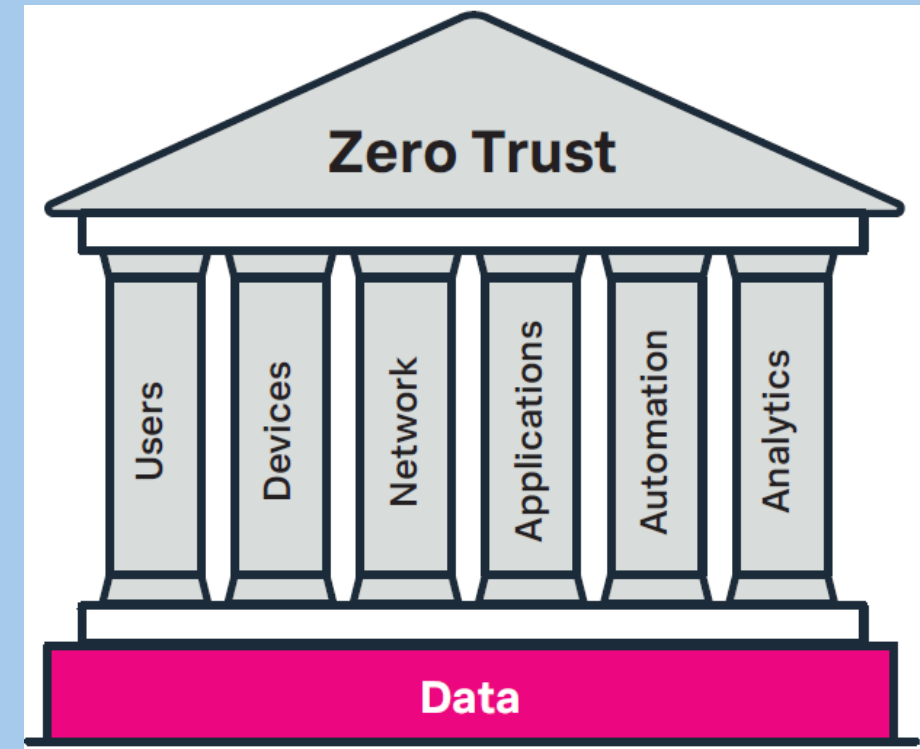
RBAC Within Zero Trust

RBAC supports Zero Trust by providing structured, scalable, and context-aware access control:

- **Enforces Least Privilege**
 - Users are assigned roles that align with job responsibilities.
 - Limits access to only what is necessary, minimizing risk and attack surface.
- **Supports Dynamic Access Control**
 - Grouping users by role allows for quick, centralized updates in response to evolving threats or organizational changes.
- **Strengthens Security Posture**
 - Reduces the potential for unauthorized access and insider threats.
 - Encourages ongoing validation of roles and permissions.
- **Scalable and Flexible**
 - Easily adapts to growing organizations.
 - Aligns with Zero Trust's need for fine-grained and adaptable permissions.

Implementing RBAC in a Zero Trust Architecture

- **Define Roles and Assign Users**
 - Based on job functions and least privilege principles.
- **Enforce Policies and Controls**
 - Establish and regularly review policies that govern access and align with continuous verification.
- **Continuous Monitoring and Adjustment**
 - Periodically reassess user roles and access rights to reflect changes in responsibilities or threat posture.



In Practice

Authentication Policy

Synopsis: To require the positive identification of the person or system seeking access to secured information, information systems, or devices.

Policy Statement:

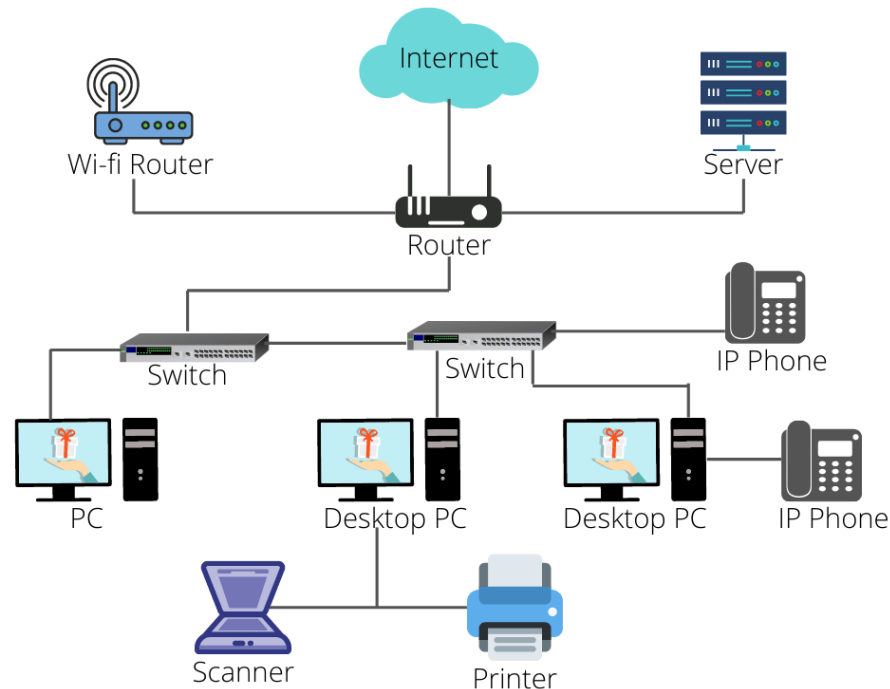
- Access to and use of information technology (IT) systems must require an individual to uniquely identify and authenticate him/herself to the resource.
- Multiuser or shared accounts are allowed only when there is a documented and justified reason that has been approved by the Office of Information Security.
- The Office of Information Security is responsible for managing an annual user account audit of network accounts, local application accounts, and web application accounts.
- Data classification, regulatory requirements, the impact of unauthorized access, and the likelihood of a threat being exercised must all be considered when deciding upon the level of authentication required. The Office of Information Security will make this determination in conjunction with the information system owner.
- The inability to technically enforce this standard does not negate the requirement.
- Password length, complexity, and expiration will be defined in the company password standard.
- The password standard will be published, distributed, and included in the acceptable use agreement.

Topics

- Access Control Fundamentals
 - Identify Management
 - Security Posture
 - Principle of Least Privilege and Need-to-Know
 - AAA
 - Access Control Models
- Infrastructure Access Controls
- Managing User Accounts

Infrastructure Access Controls /1

- A network infrastructure is defined as an interconnected group of hosts and devices.
- The infrastructure can be confined to one location or, as is often the case, widely distributed, including branch locations and home offices.

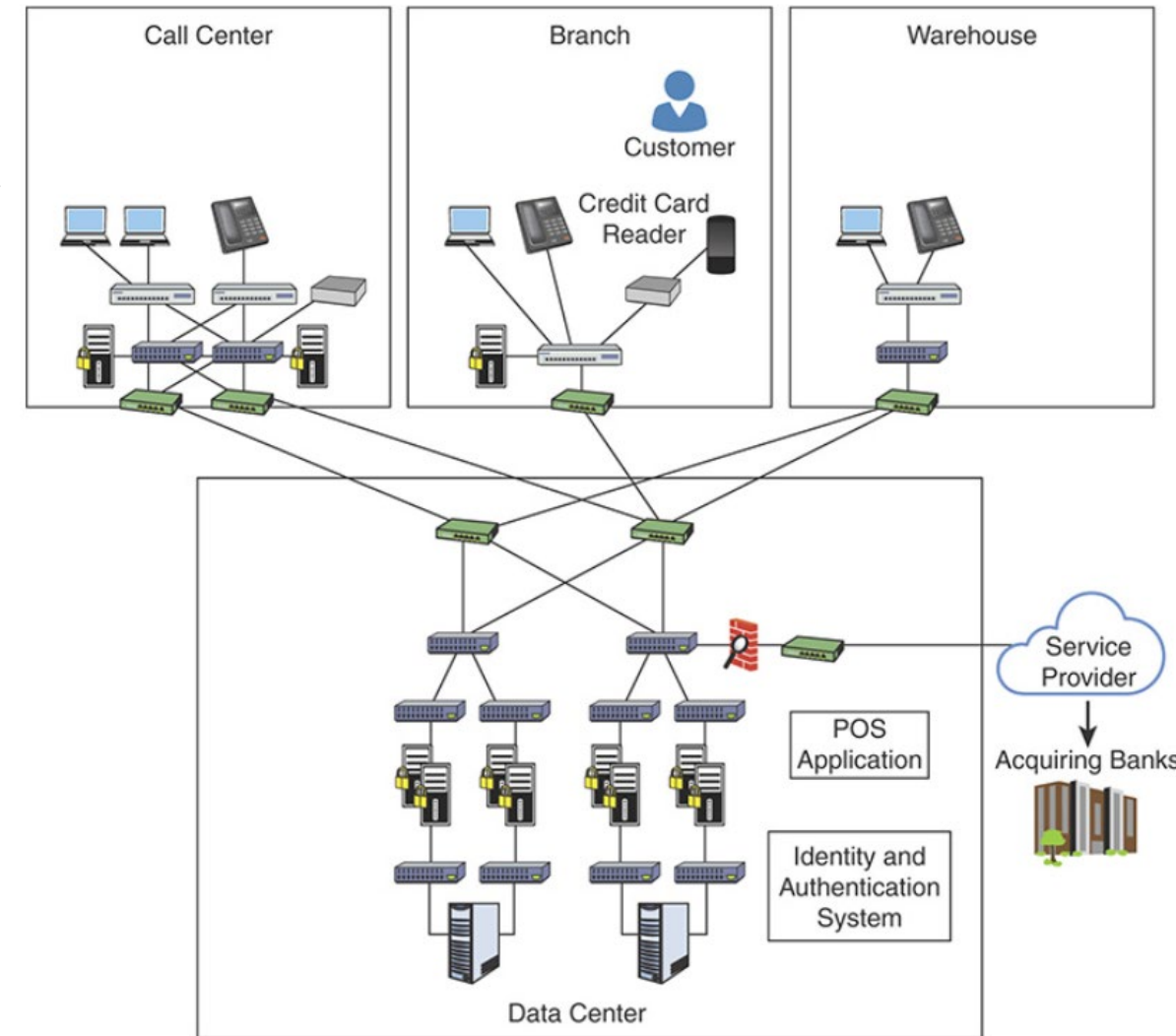


Infrastructure Access Controls /2

- Infrastructure access controls include:
 - Physical and logical network design.
 - Border devices.
 - Communication mechanisms.
 - Host security settings.
- Because no system is foolproof, access must be **continually monitored**; if suspicious activity is detected, a response must be initiated.

Network Segmentation /1

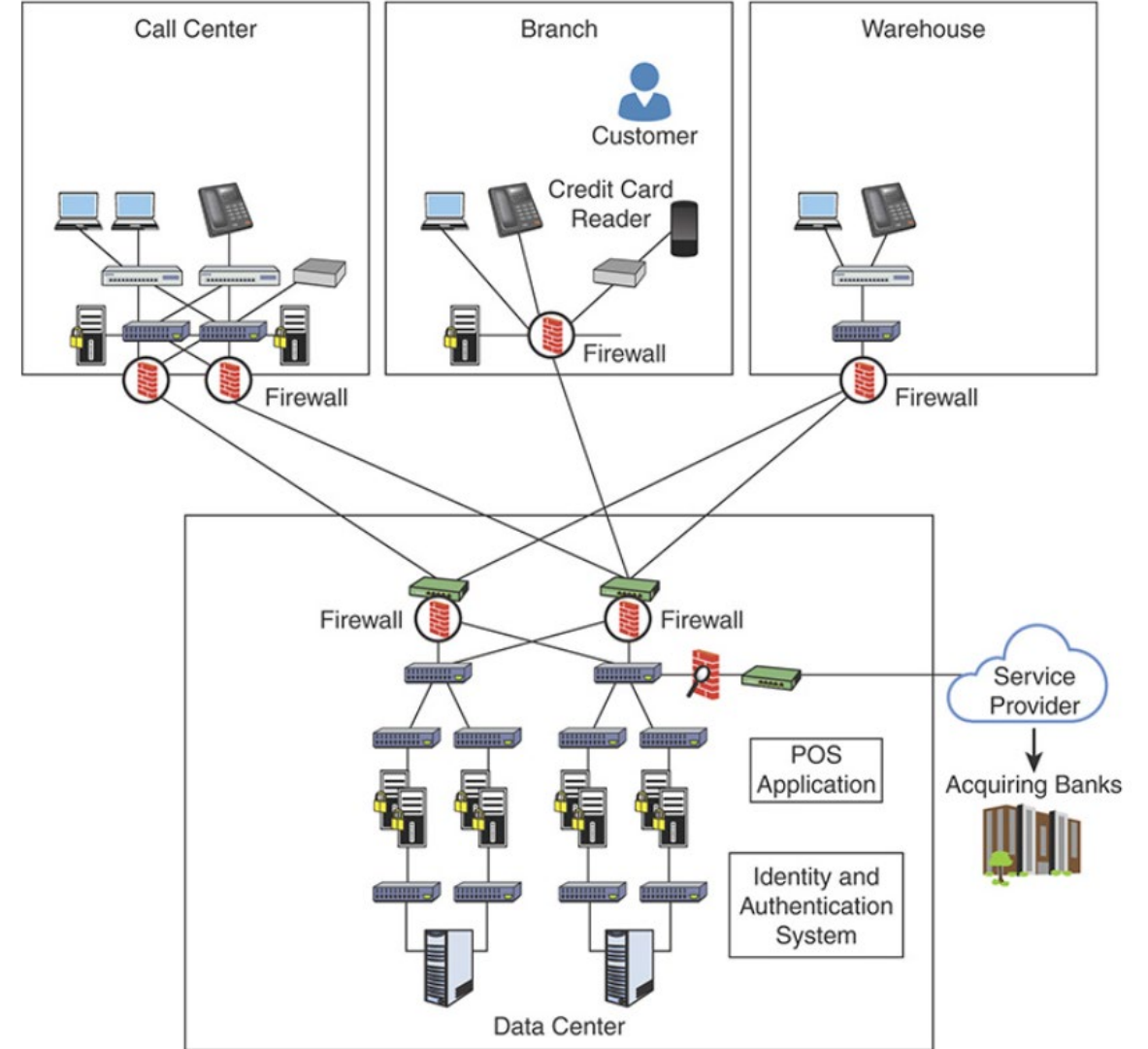
- **Network segmentation:** The process of logically grouping network assets, resources, and applications.
- Why Segment a Network?
 - Users in the call center and the warehouse have access to the resources in the Branch office and vice versa.
 - They also have access to resources in the data center.
 - If any device is compromised, an attacker can pivot (or move laterally) in the network.



Network Without Proper Segmentation

Network Segmentation /2

- Firewalls have been installed to segment the network.



Network With Segmentation

Segmentation Tools

- Several technologies can be used to segment a network:
 - Virtual LANs (VLANs)
 - vMicro-segmentation at the virtual machine level
 - Micro-segmentation for containers
 - Firewalls
 - Routers & Layer 3 Switches
 - Network Access Control (NAC) Systems
 - Zero Trust Architecture Tools

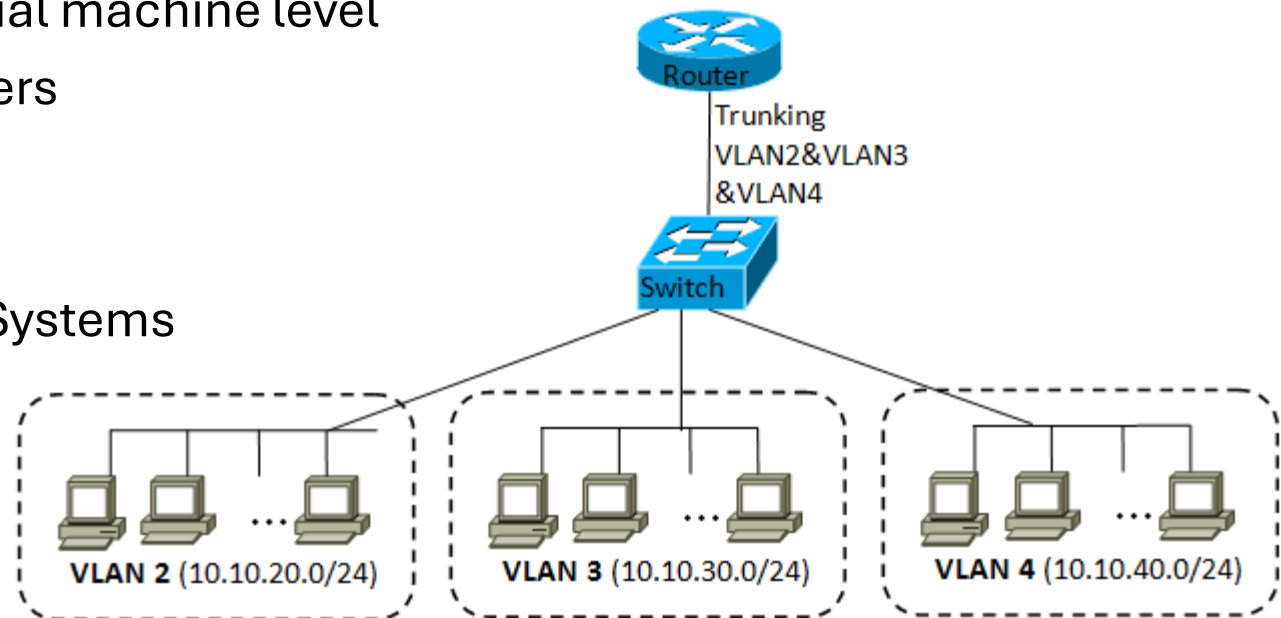
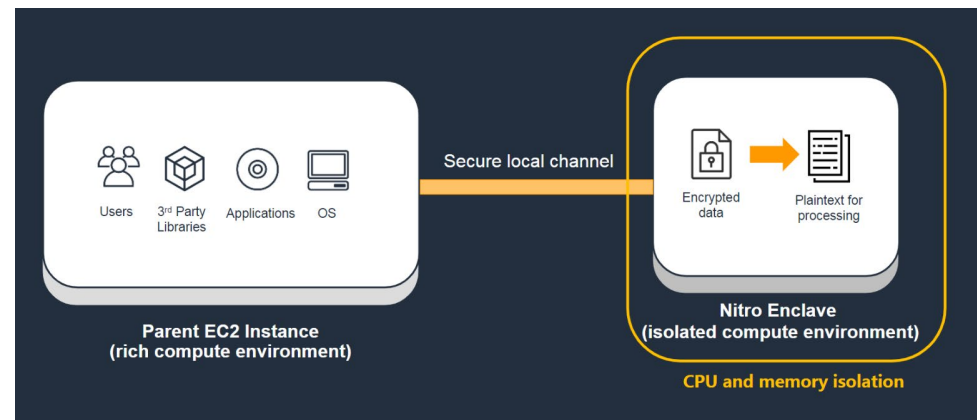


Figure 12.5. 802.1Q trunk between the router and the switch

Network Segments Types /1

- Types of network segments from the inside out:
 - **Enclave network:** A segment of an internal network that requires a higher degree of protection.
 - **Trusted network (wired or wireless):** The internal network that is accessible to authorized users.
 - **Semi-trusted network, perimeter network, or DMZ:** A network that is designed to be Internet accessible. Hosts such as web servers and email gateways are generally located in the DMZ

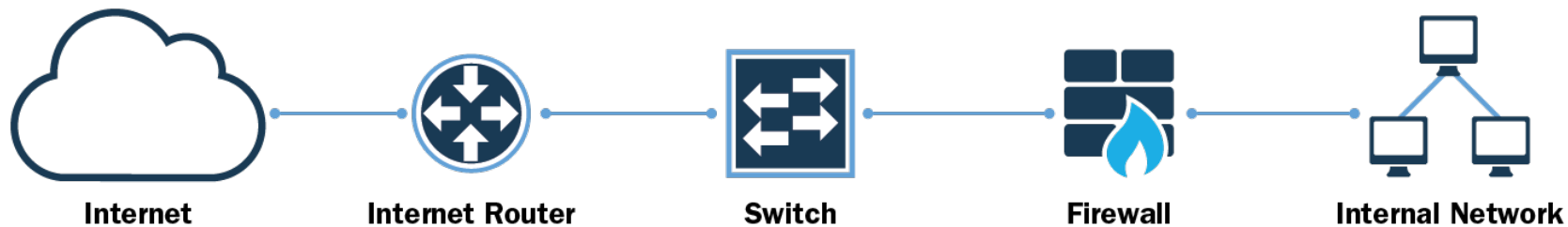


Network Segments Types /2

- Types of network segments from the inside out:
 - **Guest network (wired or wireless):** A network that is specifically designed for use by visitors to connect to the Internet. There is no access from the Guest network to the internal trusted network.
 - **Untrusted network:** A network outside your security controls. The Internet is an untrusted network.

Layered Border Security

- The focus of layered border security is to protect the internal network from external threats.
- Layered border security access controls include:
 - Firewall devices
 - Intrusion detection and prevention systems (IDPSs)
 - Content filtering and whitelisting/blacklisting
 - Border device administration and management



Remote Access Security /1

- The need to access internal corporate network resources from external locations has become increasingly common.
- In fact, for companies with a **remote** or **mobile workforce**, remote access has become the norm.



Remote Access Security /2

- The nature of remote access technologies (permitting access to protected resources from external networks and often external hosts as well) is **fraught with risk**.
- Companies should start with the assumption that external facilities, networks, and devices contain **hostile threats** that will, if given the opportunity, attempt to gain access to the organization's data and resources.



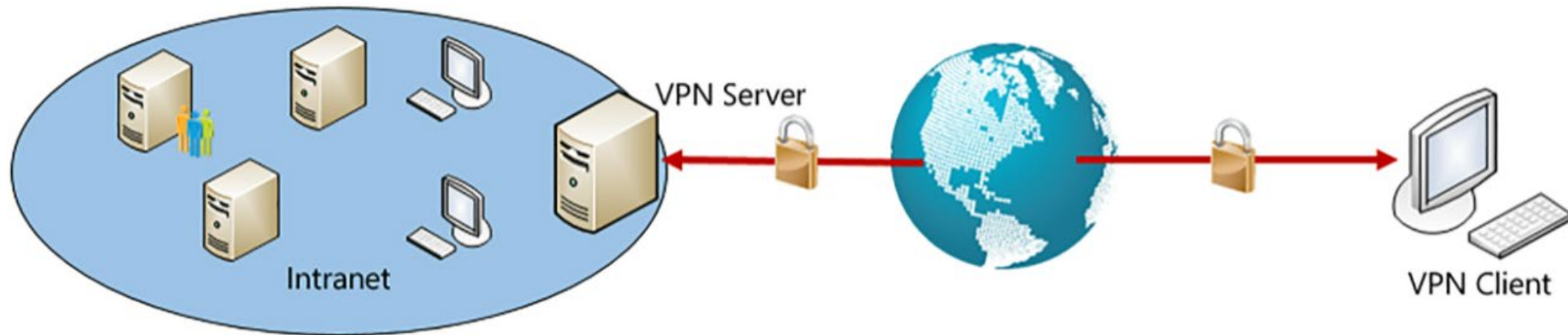
Remote Access Security /3

- Users who have a demonstrated **business need** to access the corporate network remotely and are authorized to do so must be given that privilege.
 - Not all employees should be given this privilege by default.
- Remote access activities should be **monitored** and **audited**.
- The organization's business continuity plan must account for the telecommuting environment.



Remote Access Technologies

- Virtual Private Networks (VPNs) link two computers or network devices through a wide area network (WAN) such as the Internet.
- Because the Internet is a public network and is considered insecure, the data sent between the two computers or devices is encapsulated and encrypted.
- VPN is a cost-effective solution for securing remote access.



In Practice

Remote Access Security

Synopsis: To assign responsibility and set the requirements for remote access connections to the internal network.

Policy Statement:

- The Office of Information Security is responsible for approving remote access connections and security controls.
- The Office of Information Technology is responsible for managing and monitoring remote access connection.
- Remote access connections must use 128-bit or greater encryption to protect data in transit (such as VPN, SSL, or SSH).
- Multifactor authentication must be used for remote access. Whenever technically feasible, one factor must be out-of-band.
- Remote equipment must be company-owned and configured in accordance with company workstation security standards.
- Business partners and vendors wanting to obtain approval for remote access to computing resources must have access approved by the COO. Their company sponsor is required to provide a valid business reason for the remote access to be authorized.
- Employees, business partners, and vendors approved for remote access must be presented with and sign a Remote Access Agreement that acknowledges their responsibilities prior to being granted access.
- Remote access devices must be configured to log successful and failed activity as well as configuration changes.

Topics

- Access Control Fundamentals
 - Identify Management
 - Security Posture
 - Principle of Least Privilege and Need-to-Know
 - AAA
 - Access Control Models
- Infrastructure Access Controls
- Managing User Accounts

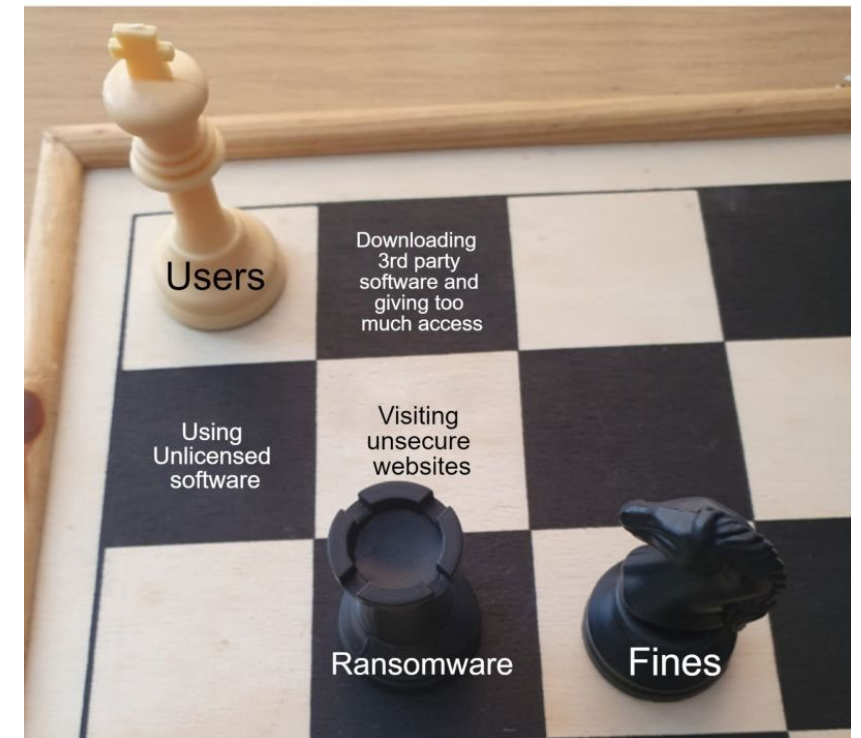
User Account Management

- User access control and management is an enterprise-wide security task.
- It requires the involvement of and communication between:
 - Human Resources
 - Information Technology
 - Information Security
 - Information System Owners

Why Manage User Access?

- To maintain confidentiality and data integrity.
- User accounts are the first target of a hacker who has gained access to an organization's network.
- Diligent care must be used when designing procedures for creating accounts and granting access to information.

Accidentally giving users full admin rights.



NIST Recommendations

NIST recommends that organizations manage information system accounts by :

- Identifying account types (individual, group, system, application, guest, and temporary)
- Establishing conditions for group membership
- Identifying authorized users of the information system and specifying access privileges
- Requiring appropriate approvals for requests to establish accounts
- Establishing, activating, modifying, disabling, and removing accounts
- Specifically authorizing and monitoring the use of guest/anonymous and temporary accounts
- Notifying account managers when temporary accounts are no longer required and when information system users are terminated or transferred or when information system usage or need-to-know/need-to-share changes
- Deactivating temporary accounts that are no longer required and accounts of terminated or transferred users
- Granting access to the system based on the following:
 - A valid access authorization
 - Intended system usage
 - Other attributes, as required by the organization or associated business functions
- Reviewing accounts periodically

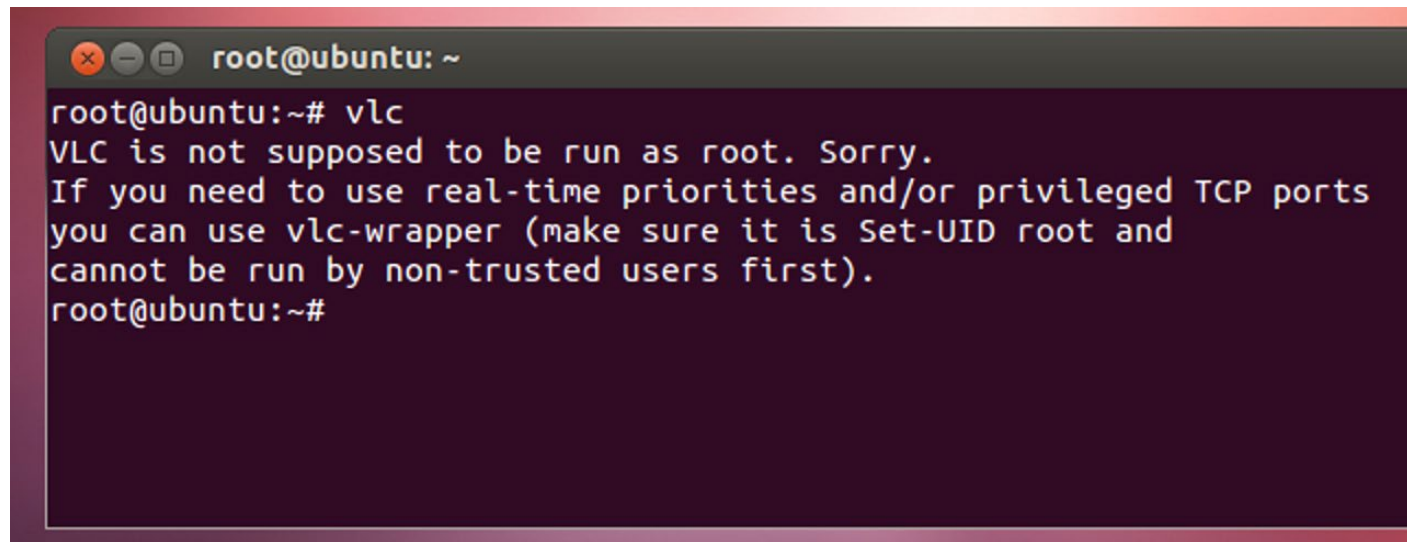
Administrative Account Controls /1

- Some accounts with elevated privileges are necessary
 - Network admin, system admin, database admin, firewall admin, webmasters
- This concentration of power can be dangerous.



Administrative Account Controls /2

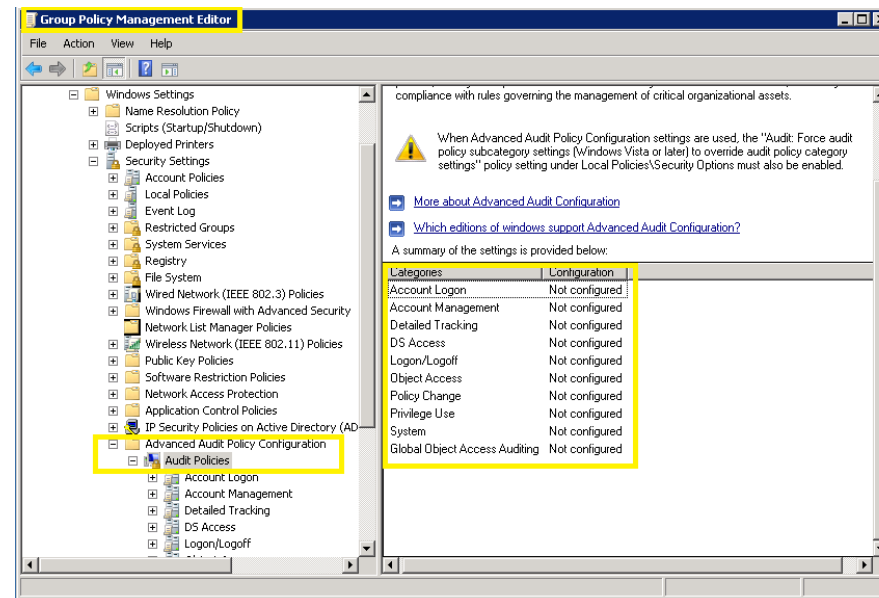
- Administrative accounts should be used only when the activity being performed requires elevated rights and permissions.
- There is no need to use this type of account to perform routine activities such as checking email, writing reports, performing research on the Internet, and other activities for which a basic user account will suffice.



```
root@ubuntu: ~  
root@ubuntu:~# vlc  
VLC is not supposed to be run as root. Sorry.  
If you need to use real-time priorities and/or privileged TCP ports  
you can use vlc-wrapper (make sure it is Set-UID root and  
cannot be run by non-trusted users first).  
root@ubuntu:~#
```

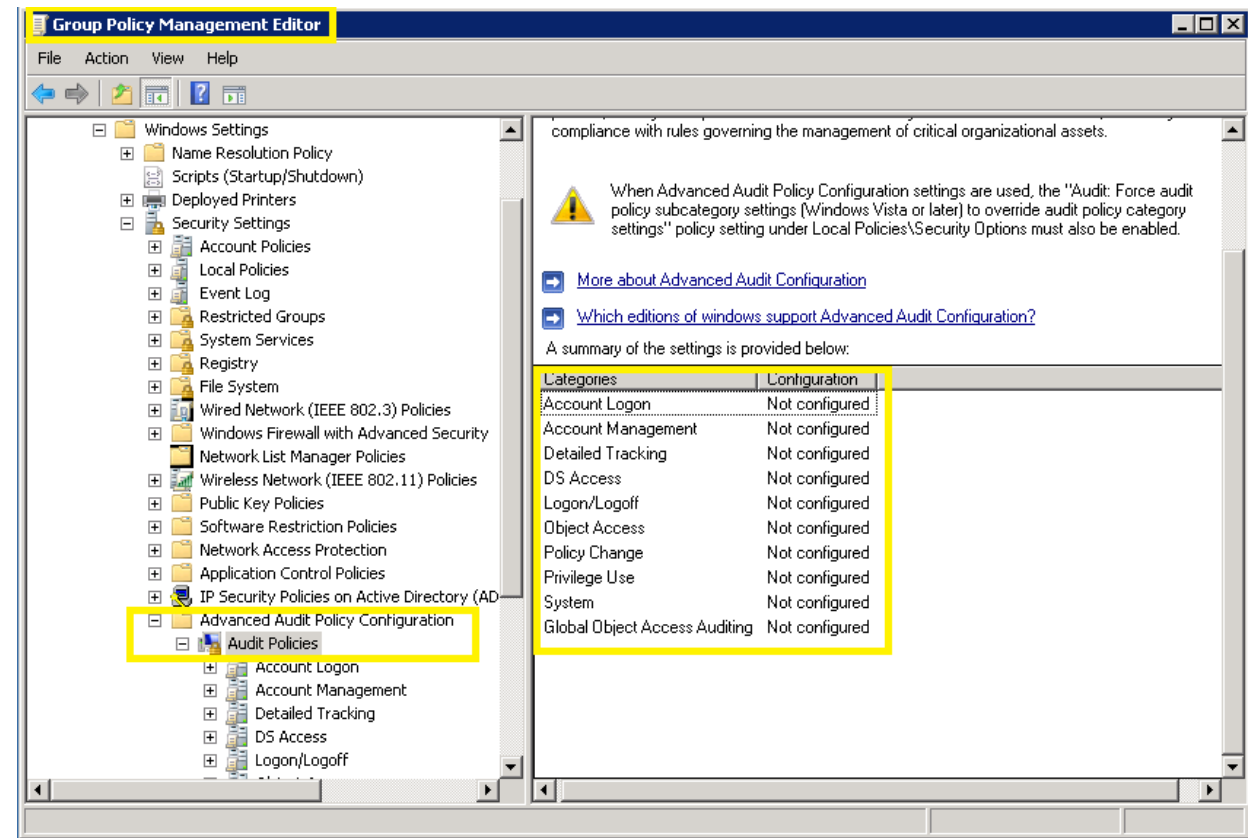
Administrative Account Controls /3

- Mitigating controls
 - Segregation of duties.
 - Dual control: requires that two individuals must both complete their half of a specific task.
 - All administrative or privileged account activity should be logged and reviewed.



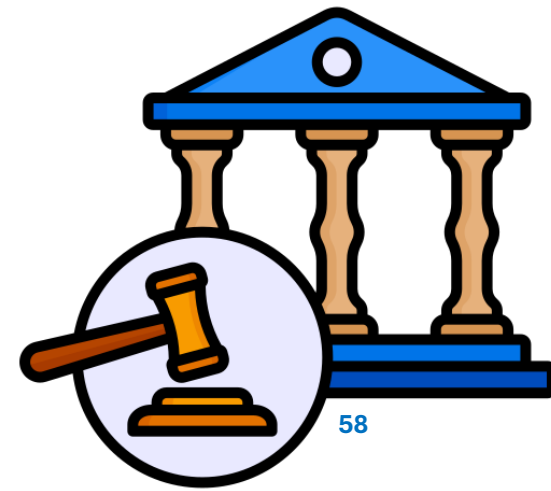
Types of Access to be Monitored

- **Successful** access: a record of user activity.
- **Failed** access: indicative of either unauthorized attempts or authorized user issues.
- **Privileged** operations: compromise or misuse of administrator accounts can have disastrous consequences.



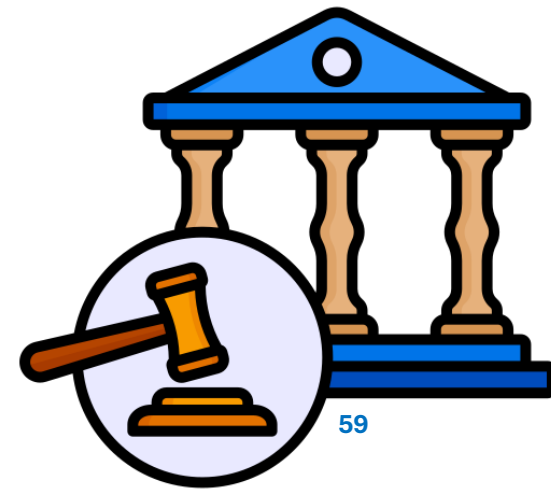
Is Monitoring Legal? /1

- Employees should have no expectation of privacy while on company time or when using company resources
- Courts have favored an employer's right to protect their interests over individual privacy rights citing reasons such as:
 - The work is done at the employer's place of business.
 - The employer owns the equipment.
 - The employer has an interest in monitoring employee activity to ensure the quality of work.
 - The employer has the right to protect property from theft and fraud.



Is Monitoring Legal? /2

- Courts indicate that monitoring is acceptable if it is reasonable:
 - **Justifiable** if serving a business purpose.
 - **Policies are set** forth to define what privacy employees should expect while on company premises.
 - **Employees are made aware** of what monitoring means are deployed.
- Acceptable use agreement should include a clause informing users that the company will and does monitor system activity.
- Users must agree to company policies when logging on.



UOIT Technology Use Policy

- <https://usgc.ontariotechu.ca/policy/policy-library/policies/legal,-compliance-and-governance/information-technology-acceptable-use-policy.php>

Office of the University Secretary and General Counsel

ABOUT US COMPLIANCE GOVERNANCE LEGAL POLICY

16.1 The University respects University Members' reasonable privacy expectations but University Members will not have an expectation of complete privacy when using the University's IT Resources.

16.2 University Members' privacy rights may be superseded by the University's right to protect:

- a. the integrity of its IT Resources;
- b. the rights of other University Members or Guests; or
- c. the University's property.

16.3 The University reserves the right to monitor and log usage of its IT Resources.

16.4 The University also reserves the right to examine and preserve material stored on or transmitted through its IT Resources at its sole discretion. Examples of situations where the University may exercise this right include but are not limited to situations where the University suspects:

- a. this Policy has been violated;
- b. any other University policy has been violated;
- c. any federal or provincial law has been violated; or
- d. examination is necessary to protect the integrity of its resources.

16.6 Authorized University Employees or service providers under contract with the University, who operate and support IT Resources, may access Electronically-Stored Information without notice to University Members in order:

- a. to address emergency problems;
- b. to perform routine system maintenance; or
- c. for any other purpose required to maintain the integrity, security and availability of the IT Resources.

In Practice

Monitoring System Access and Use Policy

Synopsis: Monitoring of network activity is necessary to detect unauthorized, suspicious, or at-risk activity.

Policy Statement:

- The Office of Information Technology, the Office of Information Security, and the Office of Human Resources are jointly responsible for determining the extent of logging and analysis required for information systems storing, processing, transmitting, or providing access to information classified as “confidential” or “protected.” However, at a minimum the following must be logged:
- Successful and failed network authentication
- Successful and failed authentication to any application that stores or processes information classified as “protected”
- Network and application administrative or privileged account activity
- Exceptions to this list must be authorized by the COO.
- Access logs must be reviewed daily by the Office of Information Technology or designee, and an activity report must be submitted to the Office of Information Security.

Usability and Security Policies

- Why do employees break security policy?

"When companies set unrealistic rules [...] users will often find ways to get around them.

Their motivation is not to break IT rules, but to get their jobs done."



The photograph depicted a street (named Konsequenz) in the University Bielefeld, Germany, at lat/long. 52.036818, 8.491467. It is visible via [Google Street View](#).







Topics

- Access Control Fundamentals
 - Identify Management
 - Security Posture
 - Principle of Least Privilege and Need-to-Know
 - AAA
 - Access Control Models
- Infrastructure Access Controls
- Managing User Accounts

Summary

- Three common attributes of access controls are identification scheme, authentication method, and authorization model
- Two fundamental security postures are Secure and Open
- The Principle of Least Privilege is a strong foundation for any access control policy
- Identities should be unique, nondescriptive, and securely issued
- Three types of authentication are single-factor, multifactor, and multilayer
- Three categories of authentication factors are knowledge, possession, and inherence
- Three authorization models are object capability, security labels, and access control lists
- Types of network segments include enclave, trusted, semi-trusted, guest, and untrusted
- Remote access technologies include VPNs and remote access portals
- These types of access should be monitored: successful, failed, and privileged operations